

05 — Decision Tables ("Which one do I pick?")

This is the file to reread. AZ-500 tests **selection under constraints**, not definitions. Every table below is a family of options the exam deliberately puts in the same question as distractors.

Add a row every time you miss a practice question. This file should be longer by exam day than it is now.

A. Identity

A1. Azure RBAC vs Entra role vs Custom role vs PIM

Requirement	Answer
Manage VMs in one resource group	Azure RBAC — Virtual Machine Contributor at RG scope
Reset user passwords in the directory	Entra role — User Administrator (or Password Administrator)
A permission set no built-in role provides, scoped to one subscription	Custom Azure role
Manage credentials for one specific app registration only	Custom Entra role scoped to that app (or Application Administrator scoped via an AU)

Admin should hold the role only when needed, with approval	PIM eligible assignment
Global Admin cannot see any Azure subscriptions	Elevate access to User Access Administrator at root scope /
Helpdesk should manage users only in the EMEA region	Administrative unit + Entra role scoped to it
Permanently prevent deletion of a production RG	Resource lock (CanNotDelete) — not RBAC

A2. Which identity does my workload use?

Scenario	Answer
Azure VM/App Service accesses Key Vault, identity should die with the resource	System-assigned managed identity
20 VMs need the same permissions under one identity	User-assigned managed identity
GitHub Actions pipeline deploys to Azure with no stored secret	Workload identity federation on an app registration
On-premises script (non-Azure) authenticates to Azure	Service principal with a certificate
Third-party SaaS needs to read directory data	App registration + application permission + admin consent
App acts on behalf of the signed-in user	Delegated permission

A3. MFA and Conditional Access

Requirement	Answer
Free tier, need MFA for everyone quickly	Security defaults
MFA only from outside the corporate network	Conditional Access + named/trusted location exclusion (P1)
Block sign-in from a country	Conditional Access with a location condition
Require a compliant Intune-managed device	Conditional Access grant control
Phishing-resistant authentication for admins	CA + authentication strength = Phishing-resistant MFA (FIDO2/WHfB/CBA)
Force password change when credentials are found leaked	User risk policy (Identity Protection, P2)
Require MFA when the sign-in looks anomalous	Sign-in risk policy (P2)
Test a policy without impacting users	Report-only mode
Block legacy authentication	CA with client apps condition = Exchange ActiveSync + other clients
Time-limit an admin's elevated access with approval	PIM , not Conditional Access

B. Networking

B1. NSG vs Azure Firewall vs WAF vs AVNM — the classic four-way

Requirement	Answer	Why not the others
Allow 443 from a subnet to a VM, deny everything else	NSG	Free, L3/L4, exactly the job
Group NICs by role so rules don't use IPs	ASG referenced in NSG rules	
Restrict outbound traffic to approved FQDNs (*.microsoft.com)	Azure Firewall application rule	NSG cannot filter by FQDN
Inspect encrypted TLS traffic / IDPS signatures / full URL filtering	Azure Firewall Premium	Standard has none of these
Block SQL injection and XSS against a web app	WAF	Firewall/NSG do not parse HTTP payloads
Stop attacks at the global edge before they reach the region	WAF on Azure Front Door	App Gateway WAF is regional
Volumetric L3/L4 flood against a public IP	DDoS Protection	WAF is L7; Firewall doesn't absorb volumetrics
Central team must enforce a rule that app owners cannot override	AVNM security admin rule (Deny)	NSGs are owned by app teams
Centrally manage many firewall policies across hubs	Azure Firewall Manager	

Layered answer for a full stack: **DDoS Protection** → **Front Door/WAF** → **Azure Firewall** → **NSG/ASG**.

B2. Private Endpoint vs Service Endpoint

Requirement	Answer
Access storage from on-premises over ExpressRoute/VPN privately	Private Endpoint
Access must come via a private IP in my VNet	Private Endpoint
Remove the public endpoint entirely	Private Endpoint + <code>publicNetworkAccess = Disabled</code>
Restrict access to one specific storage account, not all storage	Private Endpoint (or Service Endpoint Policy)
Access from a peered VNet	Private Endpoint
Free , VM-only access, subnet-level granularity is fine	Service Endpoint
Traffic must stay on the Azure backbone but cost matters	Service Endpoint
Publish my own service privately to customers	Private Link Service (behind a Standard internal LB)
Private Endpoint deployed but clients still hit the public IP	Missing <code>privatelink.*</code> Private DNS zone
On-prem clients cannot resolve the private endpoint	DNS forwarder / Azure DNS Private Resolver + conditional forwarder

B3. Connectivity and encryption

Requirement	Answer
Encrypted tunnel from a branch office to Azure	Site-to-Site VPN (IPsec/IKE)
Individual laptops connect to the VNet	Point-to-Site VPN

P2S with Microsoft Entra ID authentication	OpenVPN protocol only
P2S for Windows clients through restrictive firewalls	SSTP (TCP 443)
Enforce AES-256 on a VPN connection	Custom IPsec/IKE policy on the connection
Encrypt an ExpressRoute circuit from a provider	IPsec via VPN Gateway over private peering
Encrypt the physical links of an ExpressRoute circuit	MACsec — ExpressRoute Direct only , key in Key Vault
A and C must talk, both peered to hub B	Not peering (non-transitive) → hub NVA/Firewall + UDR, or AVNM connectivity config
Force all internet traffic through inspection	UDR 0.0.0.0/0 → Azure Firewall (forced tunnelling)

B4. Network troubleshooting tool selection

Question being asked	Tool
"Which NSG rule blocked this connection?"	IP flow verify / NSG diagnostics
"Why isn't traffic going to my firewall?"	Next hop
"Show me all rules applying to this NIC"	Effective security rules
"Alert me continuously if this link breaks"	Connection monitor
"Capture the packets"	Packet capture
"Visualise allowed and denied flows over time"	Flow logs + Traffic Analytics

B5. Securing a PaaS endpoint — escalating strictness

1. Firewall **IP rules** (weakest)
 2. **VNet rules** (service endpoints)
 3. **Private endpoint**
 4. **Public network access = Disabled**
 5. **Network Security Perimeter** (strongest — overrides the trusted-services bypass)
-

C. Compute, Storage, Databases

C1. Remote VM access

Requirement	Answer
RDP/SSH with no public IP on the VM	Azure Bastion
Record administrative sessions	Bastion Premium
Keep the public IP but open the port only on request, time-limited	JIT VM access (Defender for Servers P2)
Cheapest — no Bastion, no JIT	NSG allow rule from a specific source IP (weakest)

C2. Disk encryption

Requirement	Answer
Encrypt temp disk and cache , no VM CPU impact	Encryption at host
BitLocker/dm-crypt inside the guest , keys we control	Azure Disk Encryption (ADE) — vault needs <code>EnabledForDiskEncryption</code>

Use our own key for managed disks at rest	SSE with CMK via a disk encryption set
Double encryption at rest	Platform key + CMK (infrastructure encryption)
Protect data in use , even from Microsoft	Confidential VM / confidential disk encryption
Do nothing — it is already encrypted at rest	SSE with PMK (always on, cannot be disabled)

C3. Storage access

Requirement	Answer
Best-practice app access to blobs	Managed identity + Storage Blob Data Contributor
Give a partner read access to one container for 24 hours, revocable	Service SAS bound to a stored access policy
Most secure SAS, tied to an Entra identity	User delegation SAS (blob only, max 7 days)
Prevent anyone using the account keys	<code>allowSharedKeyAccess = false</code>
Prevent anonymous public blob reads	<code>allowBlobPublicAccess = false</code>
Force encrypted transport	Require secure transfer + min TLS 1.2
Second layer of encryption at the infra level	Infrastructure encryption — at account creation only

C4. Storage data protection

Requirement	Answer
Recover an accidentally deleted blob	Blob soft delete
Recover from an overwrite	Blob versioning
Restore a container to a point in time	Point-in-time restore (needs versioning + change feed + soft delete)
Records must be unalterable for 7 years for compliance	Time-based retention policy, LOCKED
Preserve data indefinitely for litigation	Legal hold
Prevent deletion of the whole storage account	Resource lock (CanNotDelete)
Scan uploaded files for malware	Defender for Storage — on-upload malware scanning

C5. Azure Files access method

Environment	Answer
On-prem AD DS exists, VMs domain-joined	AD DS authentication over SMB
Cloud-only, no on-prem AD	Microsoft Entra Domain Services
Entra-joined Windows clients, hybrid identities	Microsoft Entra Kerberos
Linux, no identity infrastructure	NFS 4.1 (premium, private endpoint) or account key

C6. Azure SQL protection layer

Requirement	Answer
-------------	--------

Encrypt data at rest, transparent to the app	TDE (on by default)
Encrypt at rest with our own key	TDE with customer-managed key (BYOK) in Key Vault
DBAs must not see the plaintext	Always Encrypted
Always Encrypted but still need range queries and LIKE	Always Encrypted with secure enclaves
Hide most of a credit-card number from support staff	Dynamic Data Masking
Restrict which rows a user sees	Row-level security
Prove records have not been tampered with	Ledger
Detect SQL injection attempts	Defender for SQL (advanced threat protection)
Find misconfigurations and excessive permissions	Defender for SQL vulnerability assessment
Record every query for compliance	SQL Auditing → Log Analytics/Storage/Event Hub
Eliminate SQL logins entirely	Microsoft Entra-only authentication
Stop "any Azure resource" reaching the server	Turn off <i>Allow Azure services and resources to access this server</i>

C7. Container security

Requirement	Answer
API server must have no public endpoint	Private AKS cluster
Restrict which IPs can reach a public API server	Authorized IP ranges

Control pod-to-pod traffic	Network policies (Azure/Calico/Cilium) — NSGs cannot do pods
Block privileged containers at admission	Azure Policy for AKS (Gatekeeper/OPA)
Stop use of the cluster admin kubeconfig	Disable local accounts + Entra + Azure RBAC for Kubernetes
Pod authenticates to Key Vault without a secret	Workload identity + Secrets Store CSI driver
Scan images in the registry for vulnerabilities	Defender for Containers (MDVM)
Private, CMK-encrypted, signed images	ACR Premium — private endpoint, CMK, content trust

D. Defender for Cloud and Sentinel

D1. Which Defender plan?

Threat / requirement	Plan
EDR on VMs, cheapest option	Defender for Servers Plan 1
JIT, FIM, agentless malware and secrets scanning, network map	Defender for Servers Plan 2
Malware in uploaded blobs; sensitive data exposure	Defender for Storage
SQL injection, brute force, DB vulnerability assessment	Defender for Databases (Defender for SQL)
Image vulnerabilities + runtime threats in AKS	Defender for Containers

Suspicious Key Vault access	Defender for Key Vault
Suspicious ARM control-plane operations, MicroBurst/PowerZure	Defender for Resource Manager
Web shell / dangling DNS on a web app	Defender for App Service
OWASP API risks on API Management	Defender for APIs
Prompt injection against Azure OpenAI	Defender for AI Services
Attack path analysis, cloud security explorer, governance rules, data-aware posture	Defender CSPM
Discover unknown internet-facing assets and shadow IT	Defender EASM
Secret and IaC scanning in GitHub/ADO/GitLab	DevOps security connectors

D2. Defender for Cloud posture actions

Requirement	Answer
Stop a recommendation counting against a resource, documented reason	Exemption (Waiver or Mitigated)
Make sure the misconfiguration cannot recur	Enforce (DINE policy) or Deny (Deny policy) from the recommendation
Assign an owner and a remediation deadline to a finding	Governance rules (Defender CSPM)
Assess against our internal corporate standard	Custom standard in Regulatory compliance
Assess against PCI DSS	Add the compliance standard in Environment settings

Bring on-prem servers under Defender for Cloud	Azure Arc
Send alerts to Splunk/QRadar	Continuous export → Event Hub
Keep alerts for long-term analysis and KQL	Continuous export → Log Analytics
Email the subscription owner on high-severity alerts	Email notifications
Run a Logic App when a recommendation becomes unhealthy	Workflow automation
Test the automation without a real attack	Sample alerts
Stop a known-benign alert recurring	Alert suppression rule

D3. Sentinel capability selection

Requirement	Answer
Ingest CEF logs from a network appliance	AMA + DCR via a Linux log forwarder
Ingest Entra ID sign-in logs	Microsoft Entra ID data connector
Ingest Windows security events	Windows Security Events via AMA connector + DCR
Custom detection over ingested logs	Scheduled analytics rule (KQL)
Detect within one minute	NRT rule
Correlate low-fidelity alerts across products into one incident	Fusion

Turn Defender for Cloud alerts into Sentinel incidents	Microsoft security rule (unless XDR integration/Defender portal is on)
Baseline behaviour and flag deviations, no alerts	Anomaly rule (writes to <i>Anomalies</i>)
Match logs against Microsoft's IOC feed	Microsoft Threat Intelligence Analytics rule
Auto-assign an owner and set severity on new incidents	Automation rule
Post to Teams and open a ServiceNow ticket	Playbook (Logic App) , invoked by an automation rule
Auto-close noisy incidents from one rule	Automation rule with Change status = Closed
Reference list of VIP users in queries	Watchlist
Proactively search for threats with no rule	Hunting query + bookmarks
Visualise data on a dashboard	Workbook
Investigation graph is empty	Add entity mapping to the rule
Reduce ingestion cost for a verbose, rarely-alerted table	Basic/Auxiliary logs, DCR transformation , or a summary rule
Keep logs 7 years for compliance, rarely queried	Archive tier + search job / restore

D4. "Where does this log go?"

Data	Mechanism
Windows Event Log, Syslog, performance counters from a VM	AMA + Data Collection Rule

Azure resource logs (NSG, Key Vault, SQL, Firewall)	Diagnostic settings
Azure control-plane operations	Azure Activity log (→ diagnostic setting / Sentinel connector)
Defender for Cloud alerts and recommendations	Continuous export
Third-party SIEM destination	Event Hub
Long-term cheap retention	Storage account or Archive tier

E. The constraint-word decoder

When two answers both work technically, the qualifier decides.

Phrase in the stem	Pick
"minimise administrative effort"	Built-in role/template/policy, managed identity, native connector
"minimise cost"	Service Endpoint, NSG, Defender for Servers P1, foundational CSPM, Basic logs
"least privilege"	Custom role, narrowest scope, user delegation SAS, read-only data role
"without storing credentials"	Managed identity
"must not traverse the public internet"	Private Endpoint
"from on-premises"	Private Endpoint / ExpressRoute / S2S VPN (rules out Service Endpoint)
"no public IP address"	Azure Bastion

"temporary / time-bound / requires approval"	PIM (identity) or JIT (VM ports)
"must be revocable without rotating keys"	Stored access policy
"prevent" (not detect)	Policy Deny , WAF Prevention , resource lock, AVNM Deny
"existing resources as well"	DeployIfNotExists/Modify + remediation task
"even the database administrator"	Always Encrypted
"cannot be altered or deleted for N years"	Locked time-based retention policy
"even an Owner/compromised admin"	Purge protection, immutable vault, MUA/Resource Guard, AVNM Deny
"application teams must not be able to change it"	AVNM security admin rule
"within one minute"	NRT rule
"correlate across multiple products"	Fusion
"without impacting users first"	Report-only mode (CA) / Detection mode (WAF) / Audit effect (Policy)